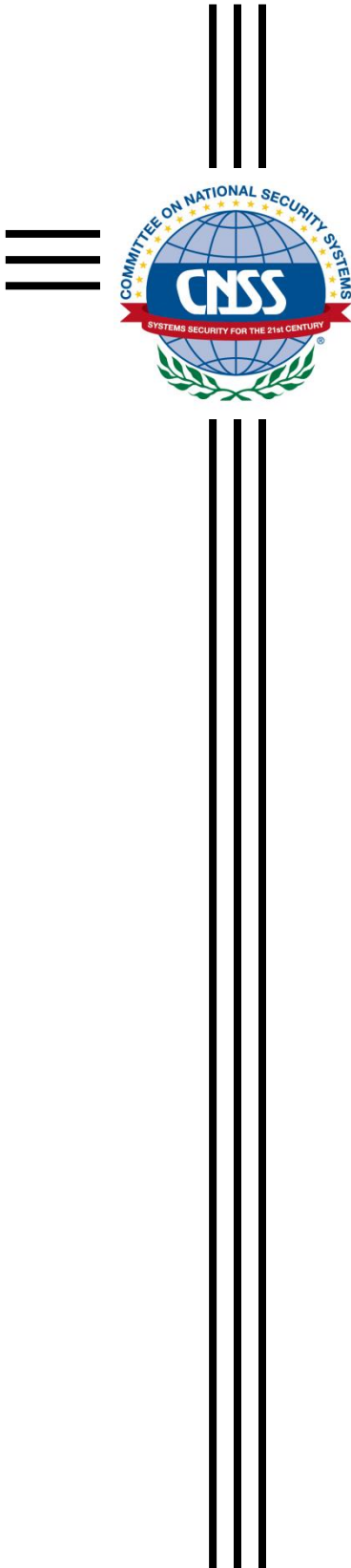


Committee on National Security Systems

CNSSD XXX



TITLE

THIS DOCUMENT PROVIDES MINIMUM EDUCATION AND TRAINING STANDARDS FOR NATIONAL SECURITY SYSTEMS. IT ALSO MAY OFFER GUIDELINES FOR THOSE PERFORMING THE SAME FUNCTIONS FOR UNCLASSIFIED SYSTEMS. YOUR DEPARTMENT OR AGENCY MAY REQUIRE FURTHER IMPLEMENATATION.



CHAIR

FOREWORD

1. The *National Policy for the Security of National Security Telecommunications and Information Systems*, dated 5 July 1990, assigns to the CNSS a key responsibility for ensuring the development and implementation of a comprehensive approach for the protection of U.S. Government national security systems and the information they store, process, or transmit. The success of this effort depends not merely on the technical implementation of policies, but also on the vulnerable interface between humans and information systems. Education, training and awareness (ETA) are countermeasures that effectively reduce the human-related risks. To maximize the overall protection of systems and information, it is essential to have a federal work force that is aware of, trained on, and educated about information assurance (IA) and Cybersecurity. This directive is issued in response to those requirements for the training of IA/Cybersecurity professionals.

2. This Directive is issued in response to national policy and establishes the requirement for federal departments and agencies to develop and implement IA/Cybersecurity education, training and awareness programs.

3. Representatives of the CNSS may obtain copies of this instruction on the CNSS website: <http://www.cnss.gov>.

/s/

CNSS CHAIR

Table of Contents

SECTION I – PURPOSE.....	1
SECTION II –AUTHORITY	1
SECTION III – SCOPE.....	1
SECTION IV – POLICY.....	1
SECTION V – RESPONSIBILITIES.....	2
SECTION VI – DEFINITIONS	3
SECTION VII – REFERENCES	3
ANNEX A	A-1
DEFINITIONS	A-1
ANNEX B	B-1
REFERENCES.....	B-1
ANNEX C	C-1
RELATED DOCUMENTS	C-1

SECTION I – PURPOSE

1. This directive establishes the requirement for federal departments and agencies to establish and implement information assurance (IA)/Cybersecurity education, training and awareness (ETA) programs for personnel who access, operate, manage, maintain, secure, develop, acquire, etc., National Security Systems (NSS).

SECTION II –AUTHORITY

2. The authority to issue this directive derives from National Security Directive 42, which outlines the roles and responsibilities for securing national security systems, consistent with applicable law, E.O. 12333, as amended, and other Presidential directives.

3. Nothing in this directive shall alter or supersede the authorities of the Director of National Intelligence.

SECTION III – SCOPE

4. This directive applies to all departments, agencies, bureaus, and offices of the U.S. Government; their employees; and supporting contractors and agents that own, operate, use, maintain, procure, secure, develop, or manage NSS, as defined in Reference ____.

SECTION IV – POLICY

5. Information Assurance/Cybersecurity ETA activities are required for all employees and contractors, who access, operate, manage, maintain, secure, develop, acquire, etc., a NSS. Such a comprehensive effort must meet the varying levels of knowledge, experience, and responsibilities of employees and contractors, as well as addressing the specific needs of individual departments and agencies. There are certain messages that need to be conveyed to both senior leadership and the workforce:

a. Organizations critically rely on the integrity of the information and availability of information system resources to meet mission requirements.

b. The organization's management is pro-actively committed to protecting information and information system resources.

c. There are consequences for inadequately protecting the organization's information systems' resources.

d. The employee is the key to a successful protection program.

SECTION V – RESPONSIBILITIES

6. Each federal department and agency will:

a. Fund, develop, and implement an IA ETA program in accordance with the National Manager guidelines and federal requirements. Every IA ETA program will contain three types of activities: initial awareness orientation, more advanced education and training commensurate with duties and responsibilities, and annual reinforcement activities.

b. Require in contract language that contractors comply with the provisions of this Directive whenever they access, operate, manage, maintain, secure, develop, acquire, etc., NSS. For contractors, the terms of the contract shall specify this requirement.

c. Ensure all training activities pursuant to the requirements of this Directive are compliant with CNSS standards and guidance and are conducted by individuals who are well versed in IA concepts and their applications.

d. Report to the National Manager annually on the status of department and agency CNSSI compliant IA activities. Metrics, as reported through FISMA, will reflect number of people trained by type of activity, viz., ETA.

7. The National Manager shall:

a. Establish, develop, and implement IA ETA program guidelines in concert with the national security community.

b. Develop national IA ETA standards and materials and review them periodically for currency and relevancy.

c. Encourage the development of ETA materials based on CNSS IA standards and guidance.

d. Encourage federal departments and agencies to develop plans of instruction mapping to CNSS standards.

e. Provide guidance to federal departments and agencies in developing and conducting IA ETA activities, as requested.

f. Coordinate with OMB to gather national security system-related IA ETA data reflecting adherence to CNSS Instructions via annual FISMA reports.

g. Brief the Committee annually on the status of department and agency CNSSI compliant IA activities. Metrics, as reported through FISMA, will reflect number of people trained by type of activity, viz., ETA.

SECTION VI – DEFINITIONS

8. Definitions in *CNSS Instruction No. 4009, National Informational Assurance (IA) Glossary, dated 26 April 2010*, (Reference a) apply to this instruction.

SECTION VII – REFERENCES

9. Future updates to referenced documents shall be considered applicable to this directive.

a. *CNSS Instruction No. 4009, National Information Assurance (IA) Glossary, dated 26 April 2010.*

b. *The National Strategy to Secure Cyberspace, Priority III: A National Cyberspace Security Awareness and Training Program, dated February 2003.*

c. *Federal Information Security Management Act of 2002 (FISMA), contained under Title III of the Electronic Government Act, dated December 17, 2002.*

Enclosures:

ANNEX A – Definitions

ANNEX B – References

ANNEX C – Related Documents

ANNEX A

DEFINITIONS

a. (U) Compromise. Disclosure of information or data to unauthorized person(s), or a violation of the security policy of a system in which unauthorized intentional or unintentional disclosure, modification, destruction, or loss of an object or information may have occurred.

b. (U) COMSEC Incident. Any uninvestigated or unevaluated occurrence that has the potential to jeopardize the security of COMSEC material or the secure transmission of classified or sensitive government information; OR any investigated or evaluated occurrence that has been determined as not jeopardizing the security of COMSEC material or the secure transmission of classified or sensitive government information. COMSEC Incidents and insecurities are categorized as cryptographic, personnel, or physical.

ANNEX B

REFERENCES

1. (U) *National Security Presidential Directive 54/Homeland Security Presidential Directive 23, Cybersecurity Policy, January 8, 2009.*
2. (U) *Public Law 107-347 [H.R. 2458], codified at 44 U.S.C. § et seq., The E-Government Act of 2002, Title III, the Federal Information Security Management Act of 2002, December 17, 2002.*
3. (U) *Committee for National Security Systems Instruction Number 4009 (CNSSI 4009), National Information Assurance (IA) Glossary, March 9, 2010.*

ANNEX C

RELATED DOCUMENTS

1. (U) [Placeholder] *National Institute of Standards and Technology DRAFT Special Publication (SP) 800-39, Integrated Enterprise-Wide Risk Management: Organization, Mission, and Information System View, December 14, 2010.*
2. (U) *OMB Policy Letter 91-3, Reporting Nonconforming Products, April 9, 1991.*
3. (U) *NIST Special Publication 800-37 Revision 1, Guide for Applying the Risk Management Framework to Federal Information Systems: A Security Life Cycle Approach, February 2010.*